

SecDevOps y Administración de Redes para Cloud

Jesús F. Rodríguez-Aragón

Sesión de Repaso

Introducción

- ▶ ¿Qué es un sistema de comunicación?
- ▶ Tipos de redes y Topologías de redes
- ▶ SecDevOps



- ▶ Integración entre
 - Desarrolladores
 - Operadores
 - Ingenieros de seguridad

El objetivo, al igual que en las metodologías ágiles, debe ser que el equipo pase de defender sus propias métricas a defender el resultado de toda la organización

- ▶ La seguridad es un servicio más de la cadena de requisitos del cliente
- ▶ Los ingenieros de seguridad añaden controles sobre el producto entregable

Introducción

► Seguridad en SecDevOps

- Detección de vulnerabilidades
 - Seguridad basada en pruebas
 - Seguridad a nivel de aplicación
 - Seguridad a nivel de infraestructura
 - Seguridad del pipeline
- Pruebas continuas
- Monitorización y respuesta a ataques
 - Registro (logs)
 - Detección de intrusiones
 - Respuesta a incidentes → Protocolo de actuación
- Evaluación de riesgos y maduración de la seguridad
 - Importancia de las métricas a partir de las pruebas de seguridad



Modelo OSI – Modelo TCP/IP (DARPA)

OSI	DARPA o TCP/IP
Aplicación	Aplication
Presentación	
Sesión	
Transporte	Transport
Red	Internetwork
Enlace	Medium Access
Físico	Phisical

Redes

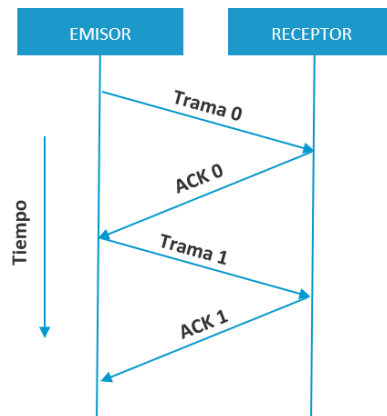
► Capa física

- Deterioro de la señal
- Medios de transmisión: guiados / no-guiados
- Protocolos de acceso al medio
 - + Particionamiento de canal → Frecuencia, Tiempo, Código
- Conmutación
 - + De circuitos → Canal exclusivo
 - + De paquetes → Cada paquete de manera independiente
 - + De mensajes → Paquetes con ruta exclusiva y almacenamiento de paquetes en nodos intermedios

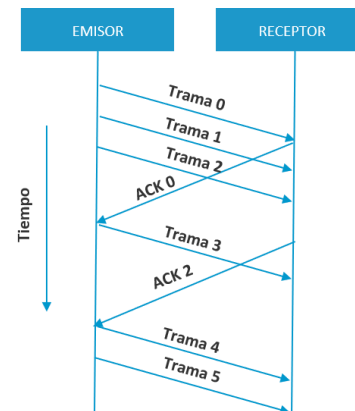
Redes

► Capa de enlace

- MAC (Control de acceso al medio) → Direccionamiento físico
- Protocolos de acceso al medio
 - + Particionamiento de canal (visto antes)
 - + Acceso aleatorio → detección de colisiones
 - + CSMA/CD
- Detección y corrección de errores: bits de paridad
- Control de flujo
 - + Stop and wait



Sliding window protocol



Redes

► Capa de red

- Direccionamiento lógico:
 - + Unicast → Host concreto
 - + Multicast → Grupo de dispositivos
 - + Broadcast → Todos los hosts de una red
 - + Anycast → Host más cercano de un grupo
- Algoritmos de enrutamiento
 - + Shortest path → Menor número de saltos
 - + Flooding → Reenvío por todas las interfaces (excepto por la que se recibió)
 - + Distance vector → cada router informa a sus vecinos de las mejores rutas
 - + Link state → Recibe información de toda la red (no sólo del vecino)
- Protocolo ARP → “Descubrimiento” de direcciones: MAC <> IP
- Protocolo ICMP → Echo request <> Echo response
- Protocolo IP: IPv4 && IPv6
- Protocolo NAT (ventajas e inconvenientes)

Redes

► Capa de transporte

- Comunicación punto a punto → Puertos → Identificación del Proceso

- TCP

 - + Orientado a conexión

 - + Fiable (número de secuencia)

 - + Control de congestión de la red → Parámetro *Window* en la cabecera (que le indica el número de bytes que puede recibir → aumenta si la transferencia es exitosa)

- UDP

 - + No orientado a conexión

 - + No fiable

 - + Mayor rendimiento → Por ejemplo, streaming

Redes

- ▶ Capa de aplicación
 - DNS
 - SMTP & POP3
 - FTP
 - HTTP
 - HTTPS
- ▶ Criptografía
 - Simétrica y Asimétrica
 - Firma

Firewalls y VPN

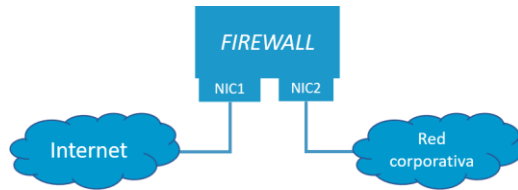
► Firewall

- Packet Filter → Inspección de tráfico
 - + Reglas en capa de red y capa de transporte
- Stateful Packet Filter → Inspección de tráfico
 - + Mantiene información sobre el estado de las conexiones
 - + Funciona a nivel de red y de transporte
- Circuit-level Gateway → Reenvío de tráfico
 - + Participan en el establecimiento de la conexión (sesiones)
 - + Funcionan a nivel de transporte / sesión
- Application-level Gateway → Reenvío de tráfico
 - + Funcionan a nivel de aplicación. Ejemplo:

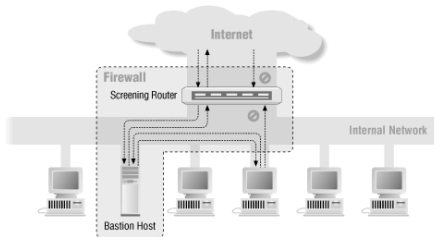
*Bloquear las peticiones PUT de FTP,
pero permitir las peticiones GET de FTP*

Firewalls y VPN

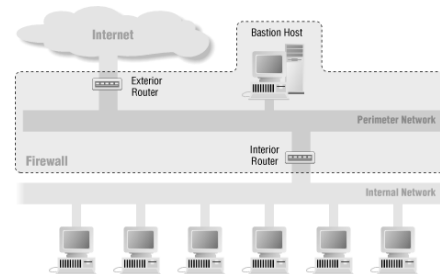
- Arquitectura del firewall
 - Dual-homed host



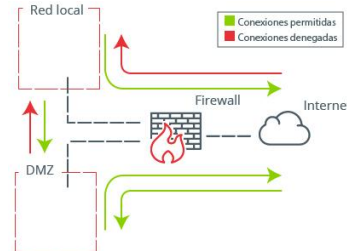
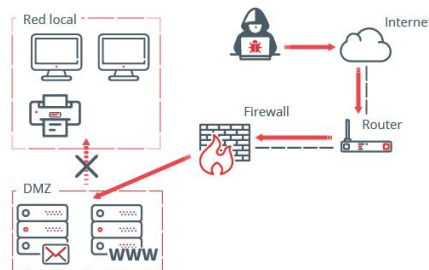
- Screened Host
 - Bastion host
 - & Screening Router
 - actúa como packet filter—



- Screened Subnet
 - Red perimetral



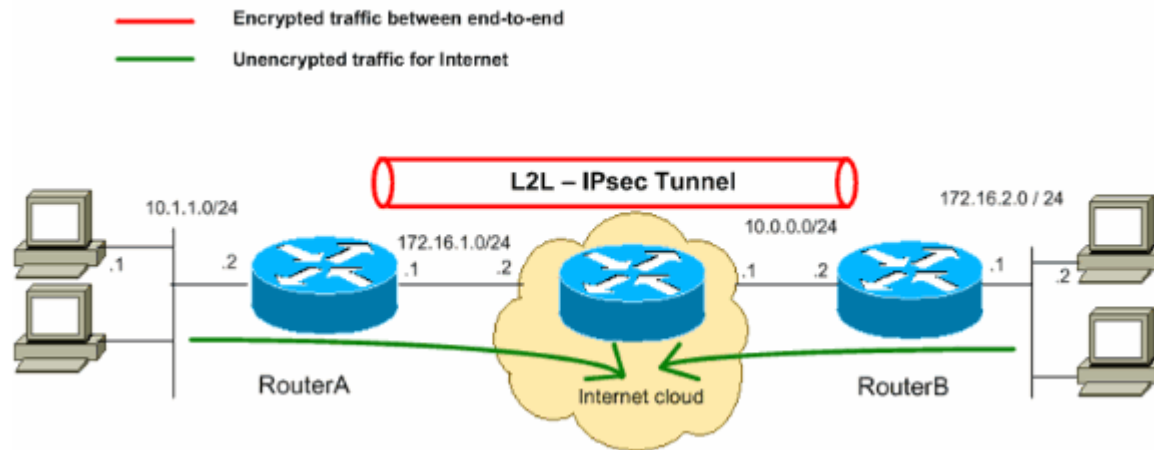
- DMZ



Firewalls y VPN

► VPN

- IPSec



+ Authentication Header (AH) → Autenticación e integridad

+ Encapsulating Security Payload (ESP) → Autenticación,
Integridad y Confidencialidad

Herramientas de seguridad en la nube

► AWS

- IAM

- + Directivas
- + Usuarios y grupos
- + Roles

- CloudTrail

- + Herramienta de auditoría

- AWS Inspector

- + Escáner de vulnerabilidades

- Amazon Detective

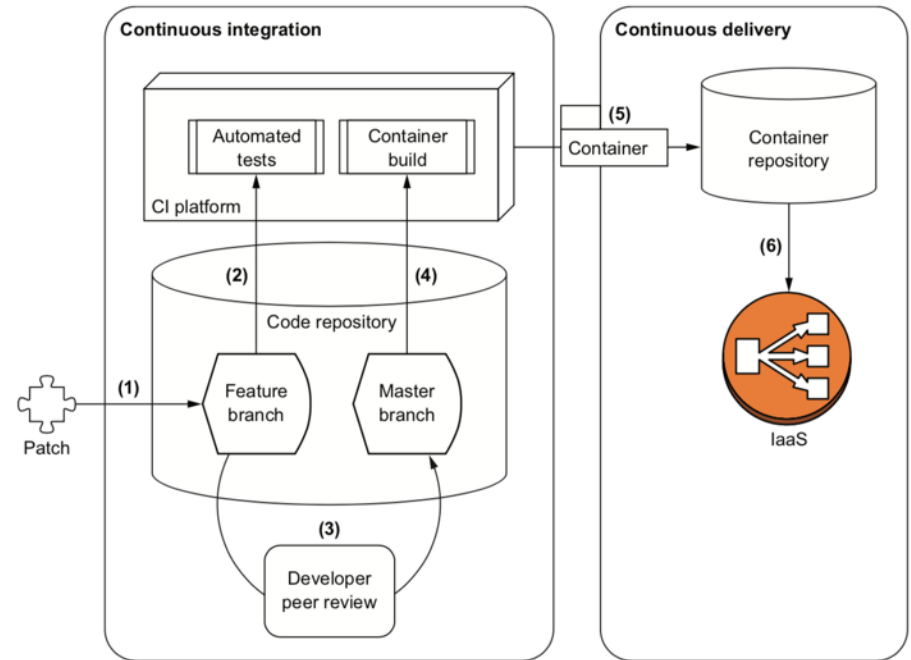
- + Analizar y procesar logs → Buscar causas e impactos de incidentes de seguridad

► Kubernetes

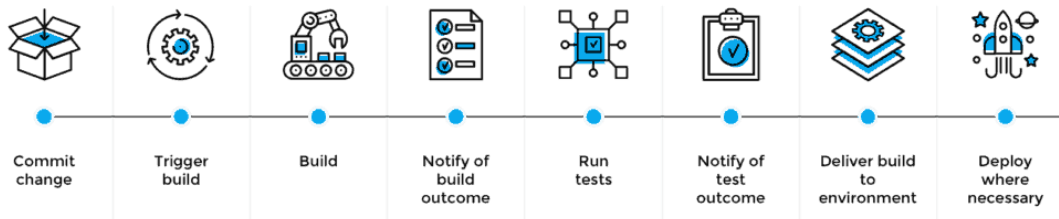
- Automatizar el despliegue, el escalado y la administración de aplicaciones → Contenedor

Seguridad DevOps

- ▶ Pruebas de aplicación
 - Vulnerabilidades
 - Autenticación
 - Dependencias
 - HTTPS
- ▶ Protección de la infraestructura
 - Pruebas de red
 - Almacenamiento / BBDD
 - Otros elementos → Bastion host, balanceador, etc
- ▶ Protección de las herramientas CI/CD
 - Repositorio de código → Firma de commits
 - Contenedores → Almacenamiento y compartición de *secretos*



CI/CD Pipeline





www.unir.net